

Strict-Transport-Security Header Not Set (Systemic)

Assessment Identifier: **WS-DYN-08** | Assessment Type: **Dynamic** | Date: **September 08, 2026**

Severity: LOW	CVSS: 3.7	CWE: CWE-319
OWASP: A05:2021 - Security Misconfiguration	WASC ID: 15	Confidence: High
Target / Component: Documentation Sitemap Route	Affected URL: https://www.worldmonitor.app/docs/sitemap.xml	Parameter: Header Missing: Strict-Transport-Security

1. Description

HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.

2. Steps to Reproduce

1. Send an HTTP GET request to https://www.worldmonitor.app/docs/sitemap.xml.
2. Inspect the HTTP response headers returned by the server.
3. Verify that the response lacks the Strict-Transport-Security header.

3. Controlled Proof of Concept

```
ZAP Response Inspection for https://www.worldmonitor.app/docs/sitemap.xml:  
The response header section does not contain any Strict-Transport-Security entry.  
  
Bash Verification:  
curl -I -s https://www.worldmonitor.app/docs/sitemap.xml | grep -i "strict-transport-security"  
(Returns empty string)
```

4. Business & Security Impact

Without an HSTS header, browsers accessing the site may initially connect over unencrypted HTTP before being redirected to HTTPS. This brief window allows network-level attackers (e.g., Man-in-the-Middle on public Wi-Fi) to perform SSL stripping attacks, intercept user communications, or downgrade secure traffic to unencrypted HTTP.

5. Remediation Recommendations

- Primary Fix:** Enforce HTTP Strict Transport Security across all routes and subdomains with a long max-age.
1. Ensure that your web server, application server, or load balancer is configured to enforce Strict-Transport-Security across all routes and subdomains.
 2. Add the Strict-Transport-Security header to all HTTPS responses with a long duration (max-age), including subdomains:
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

6. Evidence & Validation

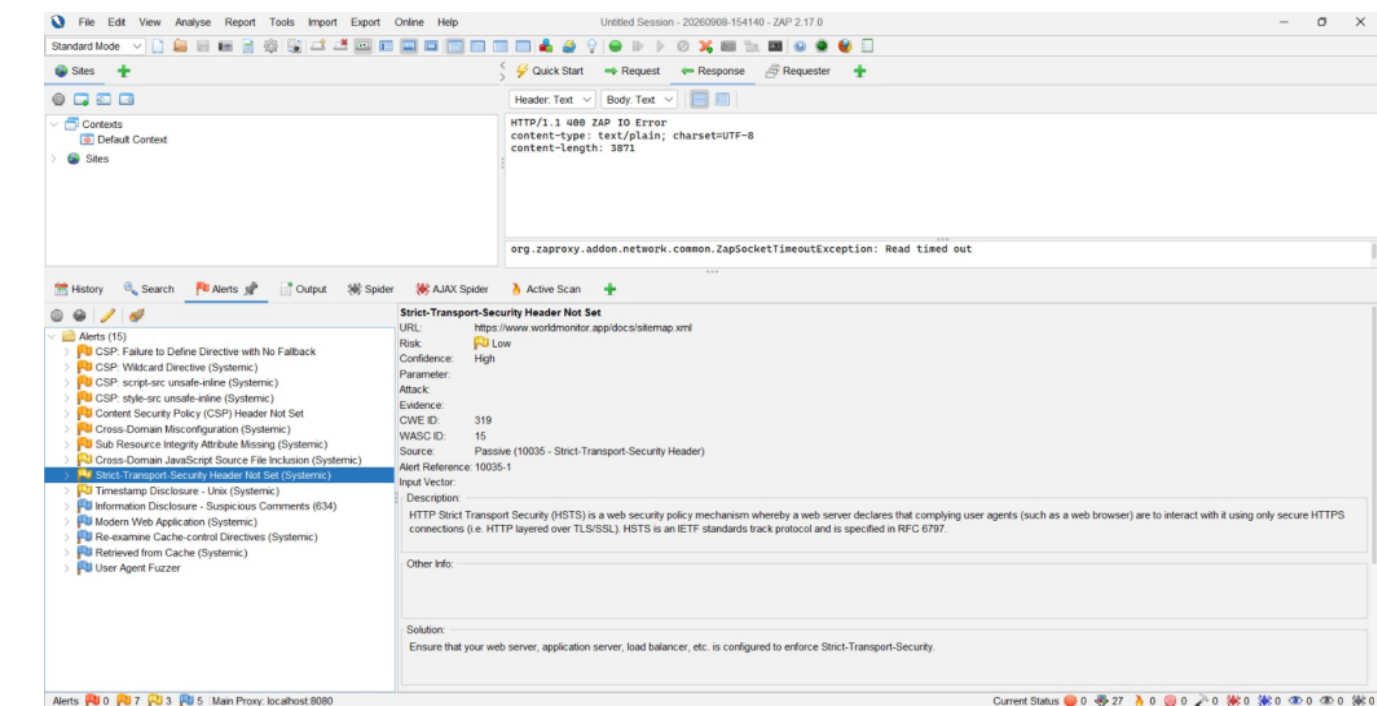


Figure 1: Matched Proof-of-Concept Screenshot for Vulnerability #8 (8/poc-1.png)

Authorization & Safety Compliance: This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.